

Documentation-Driven Threat Analysis

Base Analysis Operational Guide

Revision 2 - BA0–BA6 integrated method

Procedura source-first dalla baseline governata alla accepted Base Analysis e alle projection downstream

Stato. Consolidamento human-readable successivo alla chiusura BA6 sul corpus governato Facial Access.

Project authority. FACIAL-ACCESS-GOV-R2.

Accepted BA baseline. FACIAL-ACCESS-BA-R24-R1.

Pinned source revision. 8af2257a1df94fa5a83d4853ed0a1eb4d020c429.

Questa guida non sostituisce i contratti normativi BA0–BA6 né i documenti governati del progetto. Li organizza in una procedura leggibile e operativa.

Indice

1	Che cos'è la Base Analysis	1
2	Il contratto BA0–BA6	1
3	BAReferent e BAProposition	1
3.1	BAReferent	1
3.2	BAProposition	2
4	Il criterio di dettaglio	2
5	Procedura operativa	2
6	BA2 R3 - operatori	3
7	Ruoli e cardinalità principali	3
8	transfer.behavior	4
9	decisionRule	4
9.1	comparison	5
9.2	satisfies	5
10	constrain e property vocabulary	5
11	correlate	5
12	Acquisition: quando non scegliere un operatore	6
13	BA3 - provenance	6
13.1	sourceLink non è semantica BA2	6
14	Derivazione	6
15	Diagnostics	7
16	BA5 - authoring canonico	7
17	BA4 - projection boundary	7
18	BA6 - integrated completion	8
19	Accepted Facial Access BA	8
19.1	Referent principali	8
19.2	Flow minimo	9
19.3	Security scope	9

20 Worked proposition set	10
21 Controlled usefulness test	10
22 Regression procedure	11
23 Change e revalidation	11
24 Cosa non è la Base Analysis	11
25 Checklist operativa	12
26 Stato corrente	12

1 Che cos'è la Base Analysis

Per una baseline documentale governata, la Base Analysis è la rappresentazione analitica condivisa, methodology-neutral, del significato di progetto necessario a DDTA.

Authority boundary

```
governed project documentation
  = project authority

accepted Base Analysis
  = shared analytical baseline

projection / threat method / tests
  = downstream consumers
```

La BA può normalizzare e rendere riusabile il significato, ma non può creare silenziosamente project commitment.

2 Il contratto BA0–BA6

La metodologia corrente separa sette responsabilità.

Layer	Responsabilità
BA0	authority boundary, minimalità, unresolved state, feedback direction.
BA1	due sole famiglie first-class: BAReferent e BAProposition .
BA2	proposition semantics, operatori, ruoli, cardinalità e strutture locali.
BA3	provenance, derivazione, review/freshness, continuity e revalidation.
BA4	projection, traceability, interpretation e coverage downstream.
BA5	canonical semantic registries e controlled authoring.
BA6	accettazione integrata di una concreta BA baseline dopo coverage e regression.

BA6 non rende BA0–BA5 “più veri”: verifica che una concreta materializzazione li soddisfi insieme.

3 BAReferent e BAProposition

3.1 BAReferent

Un *BAReferent* è un significato di progetto methodology-neutral con identità indipendente quando deve essere:

- riusato da più proposition;
- qualificato o vincolato;
- correlato con altri significati;
- confrontato tra baseline;
- target di più asserzioni;
- tracciato stabilmente attraverso change/revalidation.

Può denotare participant, capability, information, behavior, state, service, contract, boundary o altro significato. Queste categorie non sono automaticamente nuove famiglie BA.

3.2 BAProposition

Una *BAProposition* è una asserzione analitica su uno o più *BAReferent*.

No proposition proxy

La proposition non è il comportamento o l'oggetto di progetto che descrive. Se quel significato deve essere riusato indipendentemente, riceve *BAReferent identity*.

Questa regola è ciò che giustifica *RecognitionCaptureDelivery* come *BAReferent* separato dalla proposition **transfer** che lo descrive.

4 Il criterio di dettaglio

La BA non replica l'intera documentazione e non ricostruisce automaticamente una architettura completa.

```
more detail
  only if needed to:
    preserve a governed distinction
    answer a material downstream question
    or expose a missing governed fact
```

Stopping test:

CONCETTO

Abbiamo abbastanza semantica per formulare la domanda e distinguere evidenza supportata, contraddetta o *NOTSPECIFIED*?

Se sì, stop. Se no, si identifica la distinzione mancante o si produce una diagnosis. Non si inventa l'implementazione.

5 Procedura operativa

1. Pin della source authority.
2. Lettura source-first.
3. Identificazione del minimum shared meaning.
4. Creazione dei *BAReferent* necessari.
5. Formulazione delle *BAProposition* con BA2.
6. Collegamento BA3 alla source evidence.
7. Registrazione di ambiguity / NOT SPECIFIED.
8. Minimum-BA acceptance preliminare.
9. Regression completa verso le fonti.
10. Pressure review della metodologia solo su counterexample concreti.
11. BA6 integrated completion.

12. Projection/downstream consumption secondo BA4.

6 BA2 R3 - operatori

La revisione R3 mantiene quattordici operatori.

Operator	Significato
transfer	conveyance di content da source a destination; optional behavior identity quando il trasferimento deve essere riusato/qualificato.
produce	actor/capability rende disponibile un risultato governato.
create	stabilisce un nuovo item/event project-semantic.
observe	legge/ispeziona significato esistente senza asserire creazione o state change.
transition	cambia stato/lifecycle di un subject.
correlate	preserva same-request/evaluation/identity/context binding.
reference	riferimento esplicito senza implicare dependency/correlation/ownership.
dependOn	prerequisite o dipendenza.
consumeService	consumo effettivo di servizio senza ownership transfer.
realize	significato concreto realizza/materializza significato astratto.
assignResponsibility	placement o negazione di responsibility/authority kind.
constrain	restriction riusabile/queryable.
classify	semantic kind method-neutral.
decisionRule	mapping operativo da condizioni/input a result.

7 Ruoli e cardinalità principali

Operator	Required	Optional
transfer	source 1; destination 1..*; content 1..*	behavior 0..1
produce	actor 1; result 1..*	input 0..*
create	actor 1; created 1..*	-
observe	actor 1; observed 1..*	result 0..*
transition	subject 1; toState 1	actor 0..1; fromState 0..1
correlate	correlatedItem 1..*; correlationContext 1	-
reference	referencer 1; referenced 1..*	-
dependOn	dependent 1; prerequisite 1..*	-
consumeService	consumer 1..*; service 1	provider 0..1
realize	abstract 1; realization 1..*	-
assignResponsibility	responsibleParty 1..*; responsibilityScope 1; responsibilityKind 1	-
constrain	constraintTarget 1; constraintValue 1..*	-
classify	classifiedReferent 1; semanticKind 1..*	-

Operator	Required	Optional
decisionRule	actor 1; input 1..*; result 1	operator-local rule

8 transfer.behavior

R3 introduce una sola estensione al transfer:

```
transfer
  behavior    -> BAREferent [0..1]
  source      -> BAREferent [1]
  destination -> BAREferent [1..*]
  content     -> BAREferent [1..*]
```

Usare **behavior** solo quando il comportamento di trasferimento deve essere target di altre proposition.

ESEMPIO FACIAL ACCESS

```
transfer
  behavior    -> RecognitionCaptureDelivery
  source      -> CameraSubsystem
  destination -> RecognitionProcessor
  content     -> RecognitionCapture
```

RecognitionCaptureDelivery permette di mantenere sullo stesso segmento:

- ConnectivityService dependency;
- WIRED_ETHERNET;
- Confidentiality;
- Integrity;
- AuthorizedProvenance.

Non si generalizza **behavior** a tutti gli operatori finché un secondo counterexample non lo richiede.

9 decisionRule

Forma minima:

```
decisionRule
  actor  -> BAREferent
  input  -> BAREferent [1..*]
  result -> BAREferent

  rule
    IF    decisionCondition
    THEN  resultAssignment [1..*]
    ELSE  resultAssignment [0..*]
```

Condition forms ammesse:

```
comparison
satisfies
allOf
anyOf
not
```

9.1 comparison

```
comparison
  referent      -> BReferent
  property      -> controlled semantic key
  comparisonKey -> equals | notEquals
  value         -> typed local value | BReferent
```

property resta obbligatoria.

9.2 satisfies

```
satisfies
  subject -> BReferent
  condition -> BReferent
```

È una forma locale a `decisionRule`. Serve quando la source governa una condizione ma non ne governa il modello interno property/value.

FR-1.1

```
allOf
  comparison
    IdentityDeterminationOutcome.outcomeKind == SUCCESS

  satisfies
    subject -> AccessAuthorizationState
    condition -> RequiredAccessAuthorizationCondition
```

Questo preserva “authorization condition satisfied” senza inventare:

```
AccessAuthorizationState.authorized = TRUE
```

10 constrain e property vocabulary

Quando la documentazione governa un dominio di valori ma non la regola di selezione:

```
constrain
  constraintTarget -> IdentityDeterminationOutcome
  constraintValue
    property -> outcomeKind
    vocabulary -> [SUCCESS, NEGATIVE, INCONCLUSIVE]
```

Non usare `constrain` come escape hatch per prose non strutturate.

11 correlate

`correlate` preserva binding di contesto.

Esempi:

```
RecognitionCapture
  <-> IdentityDeterminationRequest

IdentityDeterminationOutcome
AccessAuthorizationState
```



```
<-> same GovernedIdentity
IdentityDeterminationOutcome
<-> AccessAttempt
```

Non usare **reference** come sostituto quando il requisito richiede identità di contesto.

12 Acquisition: quando non scegliere un operatore

Il verbo documentale **acquire** non forza un nuovo operatore.

```
create
observe
produce
```

sono interpretazioni materialmente diverse.

La BA accettata mantiene:

```
RecognitionCaptureAcquisition [BAReferent]
diagnosis:
    MULTIPLE MATERIAL BA CANDIDATES
```

e non materializza una proposition falsa solo per avere un arco nel grafo.

13 BA3 - provenance

Ogni BA element meaning-bearing deve risolvere almeno a:

```
governedBaselineKey
originState
sourceLink
```

Origin states:

```
GROUNDED
DERIVED
DIAGNOSTIC_UNRESOLVED
```

13.1 sourceLink non è semantica BA2

Tre responsabilità restano distinte:

```
sourceLink
derivationBasisBinding
revalidationContext
```

Non usare provenance per simulare una relazione che BA2 non sa rappresentare.

14 Derivazione

Un elemento **DERIVED** richiede:

- role-bound derivation basis;
- immutable derivation rule revision;

- applicability contract;
- output semantic contract;
- lineage fino a governed source.

Nel baseline Facial Access corrente le proposition accettate sono normalizzazioni GROUNDED; non è necessario inventare derived semantics per completare la BA.

15 Diagnostics

La BA può accettare una diagnosis come diagnosis.

Vocabolario utile:

```
MULTIPLE MATERIAL BA CANDIDATES
BA REQUIRES UNSUPPORTED FACT
BA LOSES GOVERNED MATERIAL DISTINCTION
BA EXPOSES SOURCE CONFLICT
NOT SPECIFIED
```

REGOLA STABILE

Una diagnosis non è una project truth.

16 BA5 - authoring canonico

I semantic keys operativi devono essere canonici.

Domini distinti:

- project referent names;
- BA2 operator keys;
- operator-scoped role keys;
- semantic kind keys;
- controlled value domains.

Un synonym o una traduzione non stabiliscono equivalenza normativa automaticamente.

17 BA4 - projection boundary

Una projection è downstream.

Catena:

```
governed documentation
  -> accepted BA
    -> projection
      -> method-owned interpretation
```

Ogni meaning-bearing projection item deve tracciare alla BA.

Coverage modes:

```
EXHAUSTIVE_FOR_DECLARED_SCOPE
SELECTIVE
```

Una selective projection può omettere elementi BA senza dichiararli falsi o assenti.

18 BA6 - integrated completion

BA6 accetta una concreta baseline analitica relativa a:

```
governed project baseline
+ pinned source revision
+ BA contract revision set
+ declared shared scope
```

Envelope minimo:

```
baBaselineKey
governedBaselineKey
sourceRepositoryRevision
baContractRevisionSet
acceptedBAArtifactRef
declaredSharedScope
regressionEvidenceRef
unresolvedDiagnosticRef
reopenRule
```

Gates:

1. authority;
2. identity/proposition coherence;
3. provenance/source drill-down;
4. explicit uncertainty;
5. declared-scope semantic coverage;
6. post-BA regression;
7. projection readiness;
8. no unresolved contract pressure;
9. immutable baseline/change path.

19 Accepted Facial Access BA

La baseline analitica corrente è:

```
FACIAL-ACCESS-BA-R24-R1
```

derivata da:

```
FACIAL-ACCESS-GOV-R2
source revision:
8af2257a1df94fa5a83d4853ed0a1eb4d020c429
```

19.1 Referent principali

```
ControlledAreaAccess
AccessAttempt
```

```

AccessAuthorizationManagement
IdentityDetermination
PersonPresentAtAccessPoint
IdentityDeterminationRequest
RecognitionCapture
RecognitionCaptureAcquisition
RecognitionCaptureDelivery
CameraSubsystem
RecognitionProcessor
IdentityDeterminationOutcome
GovernedIdentity
AccessAuthorizationState
RequiredAccessAuthorizationCondition
AccessDecision
ConnectivityService
Confidentiality
Integrity
AuthorizedProvenance

```

19.2 Flow minimo

```

PersonPresentAtAccessPoint
  -> IdentityDeterminationRequest

CameraSubsystem
  -> RecognitionCapture
    bound to IdentityDeterminationRequest

RecognitionCaptureDelivery
  CameraSubsystem -> RecognitionProcessor

RecognitionProcessor
  -> IdentityDeterminationOutcome
    SUCCESS | NEGATIVE | INCONCLUSIVE

SUCCESS
  -> GovernedIdentity X

AccessAuthorizationManagement
  -> AccessAuthorizationState concerning X

ControlledAreaAccess
  -> AccessDecision for AccessAttempt

```

19.3 Security scope

```

RecognitionCaptureDelivery
  -> Confidentiality
  -> Integrity
  -> AuthorizedProvenance

```

Non:

```

whole system -> secure
AccessDecision -> Confidentiality
Outcome -> AuthorizedProvenance

```

20 Worked proposition set

Un sottoinsieme rappresentativo:

```

P-07
correlate
  correlatedItem      -> RecognitionCapture
  correlationContext -> IdentityDeterminationRequest

P-08
transfer
  behavior  -> RecognitionCaptureDelivery
  source    -> CameraSubsystem
  destination -> RecognitionProcessor
  content   -> RecognitionCapture

P-09
consumeService
  consumer -> IdentityDeterminationRealization
  service  -> ConnectivityService

P-12
constrain
  constraintTarget -> RecognitionCaptureDelivery
  constraintValue
    property  -> interconnectionMedium
    vocabulary -> [WIRED_ETHERNET]

P-13/P-14/P-15
constrain
  constraintTarget -> RecognitionCaptureDelivery
  constraintValue  -> C / I / AuthorizedProvenance

P-17
reference
  referencer -> AccessAuthorizationState
  referenced -> GovernedIdentity

P-23
decisionRule
  actor  -> ControlledAreaAccess
  input  -> IdentityDeterminationOutcome
  input  -> AccessAuthorizationState
  result -> AccessDecision

```

La lista completa e la source/provenance matrix sono nell'artifact R24_FACIAL_ACCESS_BASE_ANALYSIS_R1.md.

21 Controlled usefulness test

La BA governa:

```

RecognitionCaptureDelivery.interconnectionMedium
= WIRED_ETHERNET

```

Un consumer può escludere una minaccia la cui preconditione necessaria sia:

```

this governed delivery uses RF/wireless medium

```

Non può inferire:

```
the consumed provider infrastructure  
is wired end-to-end
```

Questa differenza mostra perché la BA deve essere abbastanza precisa da preservare una distinzione materiale, ma non deve inventare topologia.

22 Regression procedure

Dopo una material BA change:

1. ricostruire/aggiornare la BA contro la source pin;
2. verificare ogni proposition materiale;
3. verificare diagnostics e forbidden inferences;
4. controllare property scope;
5. controllare cross-MR identity/request binding;
6. rieseguire usefulness/projection check;
7. cercare un nuovo counterexample;
8. riaprire solo il contratto minimo se necessario.

23 Change e revalidation

Quando la source cambia:

```
source change  
  -> revalidationContext  
  -> impacted BA elements  
  -> RETAIN / REPLACE / RETIRE  
  -> new accepted BA baseline  
  -> rebuild projections
```

Una baseline BA accettata non viene silenziosamente mutata e riutilizzata come se le analisi storiche avessero usato la nuova semantica.

24 Cosa non è la Base Analysis

La BA non è:

- un DFD obbligatorio;
- un modello di deployment completo;
- una tassonomia STRIDE;
- una sostituzione di SysML/ArchiMate/AADL;
- una inference engine che completa il progetto;
- una raccolta di security mechanisms;
- la project authority;
- un database/grafico obbligatorio.

25 Checklist operativa

Prima di accettare una BA baseline:

1. baseline authority e source revision sono pinned?
2. ogni referent riusabile ha identity stabile?
3. ogni proposition usa operator/role canonici?
4. sto usando una proposition come proxy di un comportamento?
5. ho introdotto un fatto che la source non governa?
6. un NOTSPECIFIED è stato trasformato in default?
7. ogni elemento ha provenance sufficiente?
8. le proprietà locali restano scoped al target corretto?
9. cross-request / cross-identity bindings sono preservati?
10. la regression completa passa?
11. una projection controllata consuma la BA senza reparsing del prose?
12. esiste un counterexample corrente che richiede reopen?

26 Stato corrente

Per lo scope R24 esercitato dal corpus Facial Access:

```
BA0 PASS
BA1 PASS
BA2 R3 PASS
BA3 PASS
BA4 PASS
BA5 PASS
BA6 PASS

accepted BA baseline:
  FACIAL-ACCESS-BA-R24-R1

universal completeness:
  NOT CLAIMED

reopen:
  concrete governed counterexample
  or governed source change
```

Questa guida R2 è la guida operativa human-readable corrente per la Base Analysis.

Il passo successivo è usare la documentazione e la BA stabilizzate per revisionare i capitoli di tesi completabili prima della valutazione STRIDE/STRIDE-AI.